SÉCURITÉ APPLICATIVE – COMPTE RENDU

# OWASP Top 10

## Analyse Comparative & Étude Approfondie

**2021** vs **2025**

Explication des **TOP 3** de chaque édition et analyse des évolutions


**Étudiant :** Talel Chaanbi

**Module :** Sécurité des Applications Web


**Sujet :** OWASP Top 10 2021 vs 2025 – TOP 3 de chaque édition

**Date :** 06 Mars 2026


CONFIDENTIEL – Usage académique uniquement

## 📋 Table des Matières

1. Introduction à l'OWASP Top 10 2
2. Tableau Comparatif Complet – 2021 vs 2025 3
3. TOP 3 OWASP 2021 – A01 : Broken Access Control 4
4. TOP 3 OWASP 2021 – A02 : Cryptographic Failures 5
5. TOP 3 OWASP 2021 – A03 : Injection 6
6. TOP 3 OWASP 2025 – A01 : Broken Access Control 7
7. TOP 3 OWASP 2025 – A02 : Security Misconfiguration 8
8. TOP 3 OWASP 2025 – A03 : Software Supply Chain Failures 9
9. Analyse Comparative et Évolutions Clés 10
10. Conclusion & Recommandations 11

| 10 | 10 | 1 | 3 |
|---|---|---|---|
| CATÉGORIES 2021 | CATÉGORIES 2025 | NOUVELLE CATÉGORIE 2025 | CHANGEMENTS MAJEURS |

## 1 Introduction à l'OWASP Top 10

L'**Open Web Application Security Project (OWASP)** est une fondation à but non lucratif dédiée à l'amélioration de la sécurité des logiciels. Son document le plus célèbre, l'**OWASP Top 10**, est une liste des dix risques de sécurité les plus critiques pour les applications web.

📌 **Objectif du Top 10 :** Sensibiliser les développeurs, architectes, et organisations aux risques de sécurité les plus répandus et les plus impactants, basé sur des données réelles issues de tests d'intrusion et d'audits à l'échelle mondiale.

La liste est mise à jour périodiquement pour refléter l'évolution du paysage des menaces. La version **2021** a introduit plusieurs nouvelles catégories (Insecure Design, SSRF) ; la version **2025** reflète la montée en puissance des risques liés à la chaîne logistique logicielle (Supply Chain) et la prévalence croissante des mauvaises configurations.

⚠ **Méthodologie :** Les catégories sont classées selon des critères statistiques (taux d'incidence, nombre d'occurrences, CVEs associées) et des évaluations d'impact (exploitabilité, impact moyen pondéré), issus de contributions de centaines d'organisations mondiales.

## 2 Tableau Comparatif Complet – 2021 vs 2025

| # | OWASP Top 10 : 2021 | OWASP Top 10 : 2025 | Évolution |
|---|---|---|---|
| 1 | A01 – Broken Access Control | A01 – Broken Access Control | = Stable |
| 2 | A02 – Cryptographic Failures | A02 – Security Misconfiguration | ↑ #5→#2 |
| 3 | A03 – Injection | A03 – Software Supply Chain Failures | 🆕 Nouveau |

| # | OWASP Top 10 : 2021 | OWASP Top 10 : 2025 | Évolution |
|---|---|---|---|
| 4 | A04 – Insecure Design | A04 – Cryptographic Failures | ↓ #2→#4 |
| 5 | A05 – Security Misconfiguration | A05 – Injection | ↓ #3→#5 |
| 6 | A06 – Vulnerable & Outdated Components | A06 – Insecure Design | ↓ #4→#6 |
| 7 | A07 – Identification & Auth. Failures | A07 – Authentication Failures | ≈ Renommé |
| 8 | A08 – Software & Data Integrity Failures | A08 – Software or Data Integrity Failures | = Stable |
| 9 | A09 – Security Logging & Monitoring Failures | A09 – Security Logging & Alerting Failures | ≈ Renommé |
| 10 | A10 – Server-Side Request Forgery (SSRF) | A10 – Mishandling of Exceptional Conditions | 🆕 Nouveau |

📊 **Changements clés de 2021 → 2025 :**

- 🆕 Nouveau **A03:2025 Software Supply Chain Failures** — reflète la menace croissante des attaques de la chaîne d'approvisionnement (SolarWinds, Log4Shell, Bybit 2025).
- 🆕 Nouveau **A10:2025 Mishandling of Exceptional Conditions** — gestion défaillante des erreurs et exceptions.
- ↑ Montée **Security Misconfiguration** passe de #5 à #2 — 100% des applications testées sont affectées.
- ↓ Descente **Cryptographic Failures** (#2→#4) et **Injection** (#3→#5) — recul relatif mais toujours critiques.

## 3 TOP 3 OWASP 2021 – A01 : Broken Access Control

🔒 **A01:2021 – Broken Access Control**

Monté du rang #5 (2017) → #1 (2021) — Catégorie la plus critique

| 34 | 318 487 | 94% |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | APPS VULNÉRABLES |

### Définition

Le Broken Access Control survient lorsqu'une application ne restreint pas correctement l'accès aux ressources selon les permissions des utilisateurs. Les utilisateurs peuvent ainsi agir en dehors de leurs droits, accédant à des données ou fonctions qui ne leur sont pas autorisées.

### Vecteurs d'attaque principaux

- ✓ Violation du principe du moindre privilège — accès accordé à n'importe qui par défaut
- ✓ **IDOR** (Insecure Direct Object References) — manipulation de l'identifiant pour accéder aux données d'un autre utilisateur
- ✓ **Force browsing** — navigation directe vers des URLs non référencées mais accessibles
- ✓ Manipulation de JWT (JSON Web Token) pour élever les privilèges
- ✓ Mauvaise configuration CORS permettant l'accès depuis des origines non autorisées
- ✓ Absence de contrôle d'accès sur les méthodes POST, PUT, DELETE des APIs

🎯 **Scénario d'attaque concret**

Un attaquant modifie le paramètre `acct` dans l'URL :

```
https://bank.com/app/accountInfo?acct=notmyacct
```

Sans vérification côté serveur, l'attaquant accède au compte de n'importe quelle victime.

### Mesures de prévention

- ✓ Appliquer le **refus par défaut** — n'autoriser l'accès qu'aux ressources explicitement permises
- ✓ Implémenter les contrôles d'accès côté serveur uniquement (jamais côté client)
- ✓ Invalider les sessions côté serveur à la déconnexion
- ✓ Journaliser les échecs d'accès et alerter en cas de répétition
- ✓ Limiter le débit (rate limiting) pour les APIs afin de réduire l'impact des attaques automatisées
- ✓ Inclure des tests unitaires et d'intégration pour les contrôles d'accès

✅ **CWEs clés :** CWE-200 (Exposition d'informations à un acteur non autorisé), CWE-201, CWE-352 (CSRF), CWE-284 (Contrôle d'accès inapproprié), CWE-862 (Autorisation manquante)

## 4 TOP 3 OWASP 2021 – A02 : Cryptographic Failures

🔑 **A02:2021 – Cryptographic Failures**

Anciennement "Sensitive Data Exposure" — renommé pour cibler la cause racine

| 29 | 233 788 | 4.49% |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | TAUX D'INCIDENCE MOY. |

### Définition

Les Cryptographic Failures désignent les défaillances dans l'utilisation (ou l'absence) de mécanismes cryptographiques pour protéger les données sensibles au repos et en transit. Ces failles conduisent souvent à l'exposition de données personnelles, financières ou de mots de passe.

### Causes fréquentes

- ✓ Transmission de données en **texte clair** via HTTP, SMTP ou FTP sans chiffrement
- ✓ Utilisation d'algorithmes obsolètes : **MD5, SHA-1, DES, RC4**
- ✓ Mots de passe stockés sans hachage ou avec un hachage non salé (table arc-en-ciel possible)
- ✓ Clés cryptographiques codées en dur dans le code source
- ✓ Mode de chiffrement ECB (déterministe, révèle des patterns)
- ✓ Vecteurs d'initialisation (IV) réutilisés ou prévisibles

🎯 **Scénario d'attaque concret**

Une base de données contient des mots de passe hachés avec MD5 sans sel. Un attaquant qui exfiltre la base peut casser tous les mots de passe en moins d'une heure avec une table arc-en-ciel, car MD5 est rapide et ses collisions sont connues. Avec bcrypt (coût=12), la même attaque prendrait des années.

🎯 **Scénario 2 – Attaque Man-in-the-Middle**

Un site web ne force pas HTTPS sur toutes ses pages. Un attaquant sur un réseau Wi-Fi public intercepte le trafic HTTP, capture le cookie de session et se connecte en tant que l'utilisateur légitime (session hijacking).

### Mesures de prévention

- ✓ Classifier les données selon leur sensibilité et appliquer des contrôles adaptés
- ✓ Ne jamais stocker de données sensibles inutilement — supprimer dès que possible
- ✓ Utiliser **TLS 1.2+** avec **HSTS** (HTTP Strict Transport Security) pour toutes les communications
- ✓ Hacher les mots de passe avec **bcrypt, scrypt, Argon2 ou PBKDF2** (algorithmes adaptatifs)
- ✓ Utiliser des algorithmes modernes : **AES-256-GCM, RSA-OAEP, ChaCha20**
- ✓ Générer les clés et IV avec un **CSPRNG** (générateur pseudo-aléatoire cryptographiquement sûr)
- ✓ Désactiver le cache pour les réponses contenant des données sensibles

✅ **CWEs clés :** CWE-259 (Mot de passe codé en dur), CWE-327 (Algorithme cryptographique cassé), CWE-331 (Entropie insuffisante), CWE-916 (Hachage sans effort computationnel suffisant), CWE-319 (Transmission en clair)

## 5 TOP 3 OWASP 2021 – A03 : Injection

### A03:2021 – Injection

Descendu du rang #1 (2017) → #3 (2021) — Reste une menace critique et très répandue

| 33 | 274 228 | 32 078 |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | CVES RÉFÉRENCÉES |

### Définition

Une injection se produit lorsque des données non fiables fournies par un utilisateur sont envoyées à un interpréteur (SQL, OS, LDAP, etc.) dans le cadre d'une commande ou requête. L'attaquant peut ainsi manipuler l'interpréteur pour exécuter des commandes non prévues, accéder, modifier ou supprimer des données.

**Types d'injection courants**

- **SQL Injection** — manipulation de requêtes SQL
- **OS Command Injection** — exécution de commandes système
- **LDAP Injection** — contournement d'annuaires
- **XSS** — injection de scripts dans les pages web
- **NoSQL Injection** — MongoDB, CouchDB
- **Expression Language Injection**

→

**Conditions de vulnérabilité**

- ✗ Données non validées ni filtrées
- ✗ Requêtes dynamiques sans paramétrage
- ✗ Concaténation directe de l'entrée utilisateur
- ✗ Confiance aveugle aux ORM (Hibernate, etc.)
- ✗ Absence de tests SAST/DAST en CI/CD
- ✗ Messages d'erreur révélant la structure DB

🎯 **Scénario d'attaque – SQL Injection classique**

Code vulnérable : `SELECT * FROM users WHERE id='` + user_input + `'`
Payload injecté : `' UNION SELECT username,password,null FROM users--`
Résultat : tous les mots de passe sont extraits de la base en une seule requête.

### Mesures de prévention

- ✓ Utiliser des **requêtes paramétrées** (prepared statements) — méthode préférée
- ✓ Recourir aux **ORM** sécurisés (Hibernate, ActiveRecord) plutôt qu'au SQL brut
- ✓ Valider les entrées côté serveur avec une liste blanche (whitelist)
- ✓ Échapper les caractères spéciaux pour chaque interpréteur cible
- ✓ Intégrer des outils **SAST et DAST** dans la pipeline CI/CD
- ✓ Appliquer le principe du moindre privilège sur les comptes de base de données
- ✓ Ne jamais exposer les messages d'erreur détaillés (stack traces) à l'utilisateur

✅ **CWEs clés :** CWE-89 (SQL Injection), CWE-79 (XSS), CWE-78 (OS Command Injection), CWE-94 (Code Injection), CWE-20 (Validation d'entrée insuffisante)

## 6 TOP 3 OWASP 2025 – A01 : Broken Access Control

🔓 **A01:2025 – Broken Access Control**
Maintenu en #1 pour la 2ème édition consécutive — Portée élargie en 2025

| 40 | 1 839 701 | 100% |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | APPS TESTÉES AFFECTÉES |

⚠ **Évolution 2021 → 2025 :** Le nombre de CWEs mappés est passé de **34 → 40** et les occurrences ont explosé de **318 487 → 1 839 701** (×5,8). La catégorie intègre désormais explicitement le SSRF (CWE-918) et d'autres vecteurs émergents.

### Nouveautés 2025

En 2025, 100% des applications testées présentent une forme de Broken Access Control, contre 94% en 2021. Les APIs REST et GraphQL ont considérablement élargi la surface d'attaque. Le SSRF (Server-Side Request Forgery), qui était une catégorie séparée en A10:2021, est maintenant intégré dans A01:2025 via CWE-918.

### Vecteurs d'attaque principaux (2025)

- ✓ Violation du moindre privilège — APIs exposant des données sans contrôle d'autorisation
- ✓ IDOR sur les APIs REST : `GET /api/users/1234/profile` → modification en `/api/users/1235/profile`
- ✓ JWT mal configuré — algorithme "none" ou secret faible permettant la falsification de tokens
- ✓ CORS permissif — `Access-Control-Allow-Origin: *` sur des APIs authentifiées
- ✓ SSRF (CWE-918) — l'application accède à des ressources internes sur requête de l'attaquant
- ✓ CSRF (CWE-352) — actions exécutées à l'insu de l'utilisateur connecté

🎯 **Scénario d'attaque 2025 – IDOR sur API GraphQL**

Un attaquant authentifié modifie la requête GraphQL en changeant l'ID utilisateur :

```
query { user(id: "victim_id") { email, phone, creditCard { number } } }
```

Sans contrôle d'autorisation au niveau objet, il récupère les données bancaires d'un autre client.

### Mesures de prévention (2025)

- ✓ Refus par défaut — tout accès non explicitement autorisé est bloqué
- ✓ Contrôles d'accès centralisés côté serveur, réutilisés dans toute l'application
- ✓ Invalider les sessions JWT/tokens côté serveur à la déconnexion (blacklist ou rotation)
- ✓ Journaliser et alerter les échecs d'accès répétés (brute force d'IDOR)
- ✓ Rate limiting sur toutes les APIs
- ✓ Tester automatiquement les contrôles d'accès dans la CI/CD

✅ **CWEs clés 2025 :** CWE-200, CWE-201, CWE-352 (CSRF), CWE-918 (SSRF), CWE-284, CWE-862, CWE-639 (IDOR), CWE-1275 (SameSite Cookie)

## 7 TOP 3 OWASP 2025 – A02 : Security Misconfiguration

### A02:2025 – Security Misconfiguration

Montée de #5 (2021) → #2 (2025) — 100% des applications affectées

| 16 | 719 084 | 1 375 |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | CVES RÉFÉRENCÉES |

📈 **Montée en flèche :** La Security Misconfiguration passe de la 5ème à la 2ème place en 2025. La multiplication des services cloud, des microservices et des configurations complexes rend les erreurs de configuration de plus en plus fréquentes et impactantes.

### Définition

La misconfiguration de sécurité survient lorsqu'un système, une application ou un service cloud est configuré de façon incorrecte du point de vue de la sécurité. Cela crée des vulnérabilités exploitables sans nécessiter de compétences avancées en exploitation.

### Formes courantes de misconfiguration

- ✓ Absence de durcissement (hardening) des serveurs, conteneurs et services cloud
- ✓ **Comptes par défaut** non supprimés ou mots de passe par défaut non changés
- ✓ Messages d'erreur détaillés (stack traces) renvoyés aux utilisateurs
- ✓ Fonctionnalités inutiles activées : ports ouverts, services non nécessaires, frameworks de test
- ✓ En-têtes de sécurité HTTP absents ou mal configurés (CSP, X-Frame-Options, HSTS)
- ✓ Permissions de buckets S3 ou stockages cloud ouvertes au public
- ✓ Mode debug activé en production (exposant variables d'environnement et secrets)
- ✓ Secrets et credentials intégrés dans les pipelines CI/CD ou fichiers de configuration

🎯 **Scénario 1 – Console d'administration exposée**

Un serveur d'application laisse la console d'administration accessible avec les identifiants par défaut (admin/admin). Un attaquant scanne les paths courants, trouve `/admin` et prend le contrôle total du serveur.

🎯 **Scénario 2 – Bucket S3 public**

Un fournisseur cloud configure par défaut les permissions de partage "ouvertes à internet". Des données clients sensibles stockées dans un bucket S3 deviennent accessibles publiquement sans authentification.

### Mesures de prévention

- ✓ Processus de durcissement reproductible et automatisé pour chaque environnement (dev, QA, prod)
- ✓ Plateforme minimale — supprimer toutes les fonctionnalités, composants et docs non nécessaires
- ✓ Révision régulière des configurations dans le cadre du processus de patch management
- ✓ Architecture segmentée — isolation des composants par conteneurisation ou ACL cloud
- ✓ Envoyer des en-têtes de sécurité aux clients (CSP, HSTS, X-Frame-Options, X-Content-Type-Options)
- ✓ Vérification automatisée de l'efficacité des configurations dans tous les environnements
- ✓ Utiliser la fédération d'identité et les credentials éphémères plutôt que des clés statiques

✅ **CWEs clés 2025 :** CWE-16 (Configuration), CWE-611 (XXE), CWE-489 (Active Debug Code), CWE-614 (Cookie sans Secure), CWE-1004 (Cookie sans HttpOnly), CWE-942 (CORS permissif)

## 8 TOP 3 OWASP 2025 – A03 : Software Supply Chain Failures

🏭 **A03:2025 – Software Supply Chain Failures**

Nouvelle catégorie — #1 dans le sondage communautaire 2025 (50% des répondants)

| 6 | 215 248 | 5.72% |
|---|---|---|
| CWES MAPPÉS | OCCURRENCES TOTALES | TAUX D'INCIDENCE LE + ÉLEVÉ |

🆕 **Contexte de création :** Cette catégorie élargit l'ancienne A06:2021 "Vulnerable and Outdated Components" pour couvrir l'ensemble de la chaîne logistique logicielle : dépendances, outils de build, pipelines CI/CD, registres d'artefacts, IDEs et extensions. Les attaques de supply chain ont été classées #1 dans le sondage communautaire 2025, avec **exactement 50%** des répondants la plaçant en première position.

### Définition

Les Software Supply Chain Failures sont des compromissions ou défaillances dans le processus de construction, distribution ou mise à jour de logiciels. Elles sont souvent causées par des vulnérabilités ou des modifications malveillantes dans du code tiers, des outils ou des dépendances dont le système dépend.

### Vecteurs d'attaque

- ✓ Dépendances directes et transitives non tracées ou vulnérables
- ✓ Composants non maintenus, non supportés ou non mis à jour (OS, frameworks, bibliothèques)
- ✓ Pipeline CI/CD compromise — niveau de sécurité inférieur aux systèmes qu'il déploie
- ✓ Absence de **SBOM** (Software Bill of Materials) — inventaire des dépendances
- ✓ Séparation des droits insuffisante dans la chaîne de build
- ✓ Composants provenant de sources non fiables ou non signés
- ✓ Absence de surveillance des CVE pour les composants utilisés

**🎯 Scénario 1 – SolarWinds (2019) — Attaque d'État**

Des acteurs malveillants ont compromis le serveur de build de SolarWinds et injecté un backdoor (SUNBURST) dans la mise à jour légitime d'Orion. Environ **18 000 organisations**, dont des agences gouvernementales américaines, ont installé la mise à jour empoisonnée sans le savoir.

**🎯 Scénario 2 – Bybit Theft (2025) — Vol de 1,5 milliard $**

Une attaque supply chain ciblant un logiciel de portefeuille crypto a injecté du code malveillant qui ne s'activait que lors de transactions spécifiques. Bybit a perdu **1,5 milliard de dollars** en février 2025, la plus grande perte crypto de l'histoire liée à une supply chain attack.

**🎯 Scénario 3 – Log4Shell (CVE-2021-44228)**

Une vulnérabilité critique (RCE) dans Apache Log4j, bibliothèque Java présente dans des millions d'applications. Exploitable par un simple message de log. Utilisée pour des ransomwares, du cryptominage et des intrusions dans des infrastructures critiques mondiales.

### Mesures de prévention

- ✓ Générer et maintenir un **SBOM centralisé** pour tout le logiciel produit
- ✓ Suivre les dépendances directes ET transitives avec des outils comme **OWASP Dependency-Track**
- ✓ Surveiller en continu les CVE/NVD/OSV pour les composants utilisés
- ✓ N'utiliser que des composants depuis des sources officielles avec des **packages signés**
- ✓ Déployer en mode échelonné (canary deployments) pour limiter l'exposition
- ✓ Durcir la CI/CD avec MFA, journaux inviolables, artefacts immuables et séparation des droits
- ✓ Maintenir un processus de patch régulier basé sur les risques

✅ **CWEs clés 2025 :** CWE-1104 (Composants tiers non maintenus), CWE-1329 (Dépendance non mise à jour), CWE-1357 (Composant insuffisamment fiable), CWE-1395 (Dépendance à un composant tiers vulnérable)

## 9 Analyse Comparative – Évolutions Clés 2021 → 2025

### Ce qui a changé et pourquoi

| Aspect | OWASP 2021 | OWASP 2025 | Interprétation |
|---|---|---|---|
| **Menace #1** | Broken Access Control<br>318 487 occ. | Broken Access Control<br>1 839 701 occ. | Explosion ×5.8 des occurrences — APIs REST/GraphQL ont massifié la surface d'attaque |
| **Nouvelle entrée majeure** | SSRF (A10) — Nouvelle en 2021 | Supply Chain (A03) — Nouvelle en 2025 | Chaque édition reflète une menace émergente réelle (SolarWinds, Log4Shell) |
| **Crypto** | A02 — Rang #2 | A04 — Rang #4 | Descente relative, non disparition — la sensibilisation a progressé (adoption TLS/bcrypt) |
| **Injection** | A03 — Rang #3 | A05 — Rang #5 | Les ORM et requêtes paramétrées se sont généralisés, réduisant le taux d'incidence brut |

| Aspect | OWASP 2021 | OWASP 2025 | Interprétation |
|---|---|---|---|
| **Configuration** | A05 — Rang #5 | A02 — Rang #2 | Explosion du cloud, conteneurs, microservices = plus de configurations à sécuriser |

### Tendances structurelles observées

🔵 **Continuité (Stable)**
Broken Access Control reste #1 pour la 2ème édition. Malgré la sensibilisation, les erreurs d'autorisation persistent car elles nécessitent une logique métier précise qui ne peut pas être entièrement automatisée ni détectée par des scanners.

🟣 **Émergence (Nouveau 2025)**
Supply Chain Failures : la sophistication des attaques s'est déplacée des applications vers l'infrastructure de développement elle-même. Attaquer un fournisseur de confiance multiplie la portée par des milliers de victimes.

🟡 **Montée (Cloud Era)**
Security Misconfiguration (#5→#2) : la multiplication des services cloud, des APIs, des conteneurs Docker et des pipelines CI/CD a créé des milliers de nouveaux points de configuration, dont beaucoup sont laissés avec des paramètres par défaut non sécurisés.

🟢 **Régression relative (Bonne nouvelle)**
Injection (#1→#5) et Crypto Failures (#2→#4) régressent en rang relatif, signe que les pratiques de développement s'améliorent (ORM, bcrypt, TLS généralisés). Le défi reste la dette technique des anciens systèmes.

### Corrélations entre les TOP 3

🔗 **Interdépendances importantes :**
• Un **A03:2025 Supply Chain Attack** réussi peut déboucher sur un **A01 Broken Access Control** si du code malveillant modifie les contrôles d'autorisation.
• Une **A02:2025 Security Misconfiguration** (CORS permissif, cookies sans SameSite) facilite directement les attaques **A01** (CSRF, IDOR).
• En 2021, une **A03 Injection** exploite souvent une **A02 Cryptographic Failure** (mots de passe non hachés en base) pour amplifier l'impact.

## 10 Conclusion & Recommandations

### Synthèse des enseignements

L'analyse comparative des OWASP Top 10 2021 et 2025 révèle une évolution profonde du paysage des menaces. Si le Broken Access Control reste la menace numéro un, sa portée a été multipliée par 5,8 en 4 ans sous l'effet de la prolifération des APIs.

L'émergence des Software Supply Chain Failures en 3ème position souligne un changement de paradigme : les attaquants ne ciblent plus seulement les applications mais l'écosystème entier de leur développement et distribution.

La montée de la Security Misconfiguration (#5→#2) confirme que la complexité croissante des infrastructures cloud dépasse souvent la capacité des équipes à maintenir une posture de sécurité cohérente.

### Recommandations Prioritaires

| Priorité | Action recommandée | Catégorie ciblée |
|---|---|---|
| 🔴 Critique | Implémenter des contrôles d'accès centralisés côté serveur avec tests automatisés dans CI/CD | A01 (2021 & 2025) |

| Priorité | Action recommandée | Catégorie ciblée |
|---|---|---|
| 🔴 Critique | Générer un SBOM et mettre en place la surveillance continue des CVE de toutes les dépendances | A03:2025 |
| 🟠 Haute | Automatiser le hardening des configurations avec des benchmarks CIS et vérifications régulières | A02:2025 |
| 🟠 Haute | Remplacer tous les hachages MD5/SHA-1 par bcrypt/Argon2, forcer TLS 1.2+ avec HSTS | A02:2021 / A04:2025 |
| 🔵 Moyenne | Migrer vers des requêtes paramétrées et ORM sécurisés, intégrer SAST/DAST dans CI/CD | A03:2021 / A05:2025 |
| 🔵 Moyenne | Durcir la pipeline CI/CD avec MFA, séparation des droits et artefacts signés | A03:2025 |
| 🟢 Bonne pratique | Former les développeurs aux principes OWASP et intégrer la sécurité dans le cycle de développement (DevSecOps) | Global |

📚 **Ressources officielles :**

- OWASP Top 10 2021 : **owasp.org/Top10/2021/**
- OWASP Top 10 2025 : **owasp.org/Top10/2025/**
- OWASP ASVS (Application Security Verification Standard) : référentiel de contrôles de sécurité vérifiables
- OWASP Dependency-Track : surveillance des dépendances vulnérables
- OWASP Cheat Sheet Series : guides pratiques par catégorie de risque

## Message final

La sécurité applicative n'est pas un état mais un processus continu. Les menaces évoluent, les architectures se complexifient et les surfaces d'attaque s'élargissent. L'OWASP Top 10, mis à jour régulièrement, constitue un point de référence essentiel pour prioriser les efforts de sécurité et construire des applications résilientes.

Rapport réalisé par **Talel Chaanbi** — Module Sécurité des Applications Web — 06 Mars 2026